TI-DE

Threat Intelligence & Detection Engineering

TLP:WHITE

DETECTION INTELLIGENCE REPORT

LiteLLM PyPI Supply Chain Attack by TeamPCP

A critical supply chain compromise delivering a persistent Python backdoor to AI infrastructure environments worldwide.

CVSS SCORE	CVE	PLATFORMS	FIRST SEEN	THREAT ACTOR
9.4	CVE-2026-33634	9	2026-03-19	TeamPCP

Prepared by: Mazlum Baydar · 2026-03-26

Table of Contents

1. Executive Summary 3

2. CVE Details & Attack Chain 3

2.1 MITRE ATT&CK Techniques 4

3. Indicators of Compromise 4

4. Detection Rules 5

4.1 Sigma (SIEM-Agnostic) 5

4.2 YARA (Binary & File Analysis) 6

4.3 KQL (Microsoft Defender XDR / Sentinel) 7

4.4 XQL (Palo Alto Cortex XDR) 8

4.5 Splunk SPL 9

4.6 QRadar AQL (IBM) 10

4.7 Carbon Black Cloud 11

4.8 SentinelOne Deep Visibility 12

4.9 Kaspersky EDR Expert / KATA 13

5. References 14

1. Executive Summary

- TeamPCP injected a malicious backdoor into **litellm 1.82.7 and 1.82.8** on PyPI, a widely-used AI/LLM proxy library with millions of downloads across cloud ML and AI infrastructure environments.
- The attack plants **litellm_init.pth** inside Python's site-packages directory — a path configuration file that silently executes arbitrary code on every single Python interpreter startup (T1546.018), requiring no user interaction after initial infection.
- The payload establishes communication with TeamPCP C2 infrastructure via typosquat domains (**models.litellm.cloud**, **checkmarx.zone**) that closely mimic legitimate security vendor names to blend into normal traffic.
- Persistence is secured through a **systemd user service** (sysmon.service) that masquerades as the legitimate Sysinternals Sysmon monitoring tool to evade analyst suspicion.
- Any environment that executed `pip install litellm` between **2026-03-19 and 2026-03-24** must be treated as compromised and isolated for forensic investigation immediately.

2. CVE Details & Attack Chain

CVSS SCORE	SEVERITY	CVE ID	VERSIONS	ATTACK VECTOR
9.4	CRITICAL	CVE-2026-33634	1.82.7 & 1.82.8	PyPI Supply Chain

The attack targets developers and DevOps teams using LiteLLM as an AI model routing proxy. Infected environments include CI/CD pipelines, developer workstations, Kubernetes pods in ML clusters, and cloud inference services. The threat actor specifically targeted AI infrastructure due to its access to high-value API keys and model endpoints.

Attack Chain

STAGE 1
Supply Chain
Malicious litellm 1.82.7/1.82.8 uploaded to PyPI replacing legitimate builds
T1195.001

STAGE 2
.pth Hook
litellm_init.pth drops into site-packages, executing on every Python startup
T1546.018

STAGE 3
Persistence
sysmon.py backdoor installed; systemd user service created for reboot survival
T1547.016

STAGE 4
C2 Beacon
Outbound connections to models.litellm.cloud and checkmarx.zone typosquat C2
T1041

STAGE 5
Data Theft
Harvests LLM API keys, cloud credentials, environment variables
T1552

2.1 MITRE ATT&CK Techniques

Technique ID	Name	Usage in this Campaign
T1195.001	Supply Chain: Software Dependencies	Malicious litellm 1.82.7/1.82.8 packages uploaded to PyPI
T1546.018	Python Path Interception via .pth File	litellm_init.pth auto-executed on every Python interpreter startup
T1547.016	Boot Autostart: systemd Service	sysmon.service user-level systemd unit survives reboots without root

Technique ID	Name	Usage in this Campaign
T1036.005	Masquerading: Match Legitimate Name	sysmon.py and sysmon.service mimic Sysinternals Sysmon
T1041	Exfiltration Over C2 Channel	Beacon to models.litellm.cloud and checkmarx.zone for commands and data
T1552	Unsecured Credentials	Harvests LLM API keys, cloud tokens, and environment variables
T1059.006	Command and Scripting: Python	All backdoor execution via Python runtime, leveraging infected env

3. Indicators of Compromise

Type	Value	Description	Conf.	Source	Source URL
DOMAIN	`models.litellm.cloud`	TeamPCP C2 typosquat — NOT litellm.ai	**High**	ReversingLabs	github.com/reversinglabs/reversinglabs-yara-rules
DOMAIN	`checkmarx.zone`	TeamPCP C2 typosquat (impersonates Checkmarx vendor)	**High**	Sysdig	sysdig.com/blog/teampcp-pypi-supply-chain/
IP	`45.148.10.212`	TeamPCP staging server (masquerades as scan.aquasecurity.org)	**High**	Snyk	snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
IP	`83.142.209.11`	TeamPCP staging server (associated with checkmarx.zone)	**High**	Sysdig	sysdig.com/blog/teampcp-pypi-supply-chain/
SHA256	`ceNa7wMJnNHy1kRnNCcwJaFjWX3pORLfMh7xGL8TUjg`	litellm_init.pth malicious payload (34628 bytes)	**High**	FutureSearch	futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
FILE	`litellm_init.pth`	Malicious Python path hook installed in site-packages	**High**	Multiple	futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
FILE	`~/.config/sysmon/sysmon.py`	TeamPCP persistent backdoor script, mimics Sysmon	**High**	ReversingLabs	github.com/reversinglabs/reversinglabs-yara-rules
FILE	`~/.config/systemd/user/sysmon.service`	TeamPCP user-level systemd persistence unit	**High**	Datadog	securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp
FILE	`/tmp/pglog`	Temporary payload staging file	**Medium**	Sonatype	sonatype.com/blog/litellm-pypi-supply-chain
FILE	`/tmp/.pg_state`	Infection state tracker (prevents double-execution)	**Medium**	Sonatype	sonatype.com/blog/litellm-pypi-supply-chain
PACKAGE	`litellm==1.82.7`	Malicious PyPI package version (initial campaign)	**High**	PyPI/Checkmarx	pypi.org/project/litellm/
PACKAGE	`litellm==1.82.8`	Malicious PyPI package (.pth variant, second wave)	**High**	PyPI/ReversingLabs	futuresearch.ai/blog/litellm-pypi-supply-chain-attack/

Type	Value	Description	Conf.	Source	Source URL
ARCHIVE	`tpcp.tar.gz`	TeamPCP malware archive (payload delivery)	**High**	Kaspersky	kaspersky.com/blog/critical-supply-chain-attack-trivy-litellm-checkmarx-teampcp/
CVE	`CVE-2026-33634`	LiteLLM supply chain attack — CVSS 9.4 Critical	**High**	NVD	nvd.nist.gov/vuln/detail/CVE-2026-33634

4. Detection Rules

The following rules cover all phases of the attack chain across nine detection platforms. Each rule set is organized by attack stage, from initial package installation through C2 communication. All syntax has been verified against official platform documentation.

Sigma YAML · SIEM-Agnostic

Seven Sigma rules covering the full attack chain: malicious pip installation detection, litellm_init.pth hook file creation in site-packages, TeamPCP backdoor and systemd persistence artifacts, DNS queries to C2 typosquat domains, outbound connections to known C2 IP addresses, and temporary payload staging files. Rules are platform-agnostic and can be converted to any SIEM via sigma-cli or pySigma.

```
# CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
# CVSS 9.4 Critical | Threat Actor: TeamPCP | First Seen: 2026-03-24
# ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552

---
title: TeamPCP - Malicious LiteLLM PyPI Package Installation
id: a1b2c3d4-1111-4444-aaaa-000000000001
status: stable
description: >
  Detects installation of malicious LiteLLM PyPI packages (versions 1.82.7 and 1.82.8)
  used by TeamPCP supply chain campaign. These versions install litellm_init.pth
  which executes arbitrary code on every Python interpreter startup (T1546.018).
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://sysdig.com/blog/teampcp-pypi-supply-chain/
  - https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
logsource:
  category: process_creation
  product: linux
detection:
  selection_pip:
    Image|endswith:
      - '/pip'
      - '/pip3'
    CommandLine|contains:
      - 'litellm==1.82.7'
      - 'litellm==1.82.8'
  selection_python_m_pip:
    Image|endswith: '/python'
    CommandLine|contains|all:
      - '-m pip'
      - 'install'
    CommandLine|contains:
      - 'litellm==1.82.7'
      - 'litellm==1.82.8'
  condition: 1 of selection_*
falsepositives:
  - None — these exact version strings are confirmed malicious
level: critical
tags:
  - attack.t1195.001
  - attack.initial_access
  - cve.2026.33634

---
title: TeamPCP - Malicious .pth Hook File in site-packages (T1546.018)
id: a1b2c3d4-2222-4444-aaaa-000000000002
status: stable
description: >
  Detects creation of litellm_init.pth in any Python site-packages directory.
  Python .path configuration files (.pth) are auto-executed on interpreter
  startup, making this a stealthy persistence and code execution mechanism.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
  - https://github.com/reversinglabs/reversinglabs-yara-rules
logsource:
  category: file_event
  product: linux
detection:
  selection:
    TargetFilename|contains: 'site-packages'
    TargetFilename|endswith: 'litellm_init.pth'
  condition: selection
falsepositives:
  - None — legitimate litellm does not ship this file
level: critical
tags:
```

```yaml
  - attack.t1546.018
  - attack.persistence
  - cve.2026.33634

---
title: TeamPCP - Backdoor Script Created at Hidden sysmon Path
id: a1b2c3d4-3333-4444-aaaa-000000000003
status: stable
description: >
  Detects creation of ~/.config/sysmon/sysmon.py, TeamPCP's persistent
  backdoor. The path mimics the legitimate Sysinternals Sysmon to evade detection.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://github.com/reversinglabs/reversinglabs-yara-rules
logsource:
  category: file_event
  product: linux
detection:
  selection:
    TargetFilename|contains: '/.config/sysmon/'
    TargetFilename|endswith: 'sysmon.py'
  condition: selection
falsepositives:
  - None expected on Linux systems
level: high
tags:
  - attack.t1036.005
  - attack.defense_evasion
  - cve.2026.33634

---
title: TeamPCP - systemd User Persistence Unit (T1547.016)
id: a1b2c3d4-4444-4444-aaaa-000000000004
status: stable
description: >
  Detects creation of ~/.config/systemd/user/sysmon.service.
  TeamPCP uses user-level systemd to survive reboots without root privileges.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp-supply-chain-campaign/
logsource:
  category: file_event
  product: linux
detection:
  selection:
    TargetFilename|contains: '/.config/systemd/user/'
    TargetFilename|endswith: 'sysmon.service'
  condition: selection
falsepositives:
  - None — legitimate sysmon.service does not exist in Linux user systemd
level: high
tags:
  - attack.t1547.016
  - attack.persistence
  - cve.2026.33634

---
title: TeamPCP - DNS Query to C2 Typosquat Domains
id: a1b2c3d4-5555-4444-aaaa-000000000005
status: stable
description: >
  Detects DNS resolution of confirmed TeamPCP C2 domains.
  models.litellm.cloud impersonates litellm.ai; checkmarx.zone impersonates
  the legitimate Checkmarx vendor.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://sysdig.com/blog/teampcp-pypi-supply-chain/
logsource:
  category: dns_query
  product: linux
detection:
  selection:
    QueryName|endswith:
      - 'models.litellm.cloud'
      - 'checkmarx.zone'
  condition: selection
falsepositives:
```

```
  - None — confirmed malicious C2 infrastructure
level: critical
tags:
  - attack.t1041
  - attack.command_and_control
  - cve.2026.33634

---
title: TeamPCP - Network Connection to C2 IP Infrastructure
id: a1b2c3d4-6666-4444-aaaa-000000000006
status: stable
description: >
  Detects outbound connections to TeamPCP staging infrastructure.
  45.148.10.212 masquerades as scan.aquasecurity.org.
  83.142.209.11 serves as the checkmarx.zone C2 endpoint.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
logsource:
  category: network_connection
  product: linux
detection:
  selection:
    DestinationIp:
      - '45.148.10.212'
      - '83.142.209.11'
  condition: selection
falsepositives:
  - None — confirmed malicious IPs
level: critical
tags:
  - attack.t1041
  - attack.command_and_control
  - cve.2026.33634

---
title: TeamPCP - Temporary Payload Drop Files in /tmp
id: a1b2c3d4-7777-4444-aaaa-000000000007
status: stable
description: >
  Detects creation of /tmp/pglog (payload staging) and /tmp/.pg_state
  (infection state tracking) used by TeamPCP to manage payload execution.
author: Mazlum BAYDAR
date: 2026/03/26
references:
  - https://www.sonatype.com/blog/litellm-pypi-supply-chain
logsource:
  category: file_event
  product: linux
detection:
  selection:
    TargetFilename:
      - '/tmp/pglog'
      - '/tmp/.pg_state'
  condition: selection
falsepositives:
  - PostgreSQL may write to /tmp/pglog — verify initiating process is not python/pip
level: medium
tags:
  - attack.t1036
  - attack.defense_evasion
  - cve.2026.33634
```

YARA

Binary & File Analysis

Four YARA rules for static file analysis: the primary rule matches litellm_init.pth payload content by combining Python execution markers with C2 domain strings; a second rule targets the sysmon.py backdoor script by correlating C2 beaconing strings with state-tracking file paths; a third rule detects the sysmon.service systemd unit structure; a fourth rule identifies malicious package metadata (METADATA files with version 1.82.7/1.82.8 referencing litellm_init.pth). Suitable for endpoint scanners, sandbox pipelines, and file integrity monitoring.

```
/*
 * CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
 * CVSS 9.4 Critical | Threat Actor: TeamPCP | First Seen: 2026-03-24
 * ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
 */

rule TeamPCP_LiteLLM_PTH_Hook_File
{
    meta:
        description   = "Detects litellm_init.pth malicious Python path hook installed by TeamPCP supply chain attack"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "critical"
        mitre_attack  = "T1546.018"
        reference     = "https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/"
        hash_sha256   = "ceNa7wMJnNHy1kRnNCcwJaFjWX3pORLfMh7xGL8TUjg"

    strings:
        /* .pth files that execute code use 'import' prefix on each line */
        $pth_exec1    = "import subprocess" ascii nocase
        $pth_exec2    = "import os" ascii nocase
        $pth_exec3    = "import sys" ascii nocase

        /* TeamPCP C2 domains embedded in payload */
        $c2_domain1   = "models.litellm.cloud" ascii wide
        $c2_domain2   = "checkmarx.zone" ascii wide

        /* TeamPCP artifact paths */
        $path_sysmon  = ".config/sysmon/sysmon.py" ascii
        $path_service = ".config/systemd/user/sysmon.service" ascii
        $path_pglog   = "/tmp/pglog" ascii
        $path_pgstate = "/tmp/.pg_state" ascii

        /* Archive payload name */
        $archive      = "tpcp.tar.gz" ascii

    condition:
        /* .pth hook: has Python exec prefix + C2 or artifact path */
        (any of ($pth_exec*) and (any of ($c2_domain*) or any of ($path_*)))
        or
        /* Archive: named tpcp with C2 domain reference */
        ($archive and any of ($c2_domain*))
        or
        /* Any two TeamPCP artifact paths together */
        2 of ($path_*)
}

rule TeamPCP_Backdoor_Script_sysmon_py
{
    meta:
        description   = "Detects TeamPCP persistent backdoor script masquerading as sysmon.py"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "high"
        mitre_attack  = "T1036.005, T1547.016"
        reference     = "https://github.com/reversinglabs/reversinglabs-yara-rules"

    strings:
        /* Python script with C2 beaconing and /tmp state tracking */
        $beacon1      = "checkmarx.zone" ascii wide
        $beacon2      = "models.litellm.cloud" ascii wide
        $state_file   = "/tmp/.pg_state" ascii
        $payload_drop = "/tmp/pglog" ascii

        /* Common backdoor patterns */
        $exec_cmd     = "subprocess" ascii
        $encode_b64   = "base64" ascii
```

```
    condition:
        any of ($beacon*) and (1 of ($state_file, $payload_drop)) and any of ($exec_cmd, $encode_b64)
}

rule TeamPCP_systemd_Service_Unit
{
    meta:
        description   = "Detects TeamPCP sysmon.service systemd persistence unit content"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "high"
        mitre_attack  = "T1547.016"
        reference     = "https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp-supply-chain-campaign/"

    strings:
        /* systemd unit file structure markers */
        $unit_section = "[Unit]" ascii
        $svc_section  = "[Service]" ascii
        $install_sec  = "[Install]" ascii

        /* ExecStart pointing to the backdoor */
        $execstart    = "ExecStart" ascii
        $sysmon_path  = "sysmon.py" ascii

        /* WantedBy for user-level persistence */
        $wantedby     = "WantedBy" ascii

    condition:
        all of ($unit_section, $svc_section, $execstart, $sysmon_path)
}

rule TeamPCP_Malicious_PyPI_Package_Indicators
{
    meta:
        description   = "Detects TeamPCP IOCs in Python package installation artifacts (setup.py, METADATA, dist-info)"
        author        = "Mazlum BAYDAR"
        date          = "2026-03-26"
        severity      = "critical"
        mitre_attack  = "T1195.001"
        reference     = "https://sysdig.com/blog/teampcp-pypi-supply-chain/"

    strings:
        /* Malicious version strings in METADATA */
        $ver_1        = "Version: 1.82.7" ascii
        $ver_2        = "Version: 1.82.8" ascii

        /* .pth file reference in package data */
        $pth_ref      = "litellm_init.pth" ascii

        /* C2 endpoints */
        $c2_1         = "models.litellm.cloud" ascii wide
        $c2_2         = "checkmarx.zone" ascii wide

    condition:
        (1 of ($ver_*) and $pth_ref)
        or
        (1 of ($ver_*) and 1 of ($c2_*))
}
```

KQL Microsoft Defender XDR · Microsoft Sentinel

Seven KQL queries for Microsoft environments: process event hunting for malicious pip invocations, file event detection for litellm_init.pth creation, composite rule covering all TeamPCP artifact paths, DNS and network event correlation for C2 domains and IPs, a correlated query joining DeviceProcessEvents with DeviceNetworkEvents to catch Python processes connecting to C2 infrastructure, and a Sentinel-compatible SecurityEvent rule using EventID 4688. Time ranges default to 7 days and can be adjusted via the ago() function.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Microsoft Defender XDR + Microsoft Sentinel
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Author: Mazlum BAYDAR | Date: 2026-03-26

// ============================================================
// RULE 1: Malicious LiteLLM Package Installation
// Table: DeviceProcessEvents | T1195.001 Initial Access
// ============================================================
DeviceProcessEvents
| where TimeGenerated > ago(7d)
| where FileName in~ ("pip", "pip3", "python", "python3")
| where ProcessCommandLine has_any ("litellm==1.82.7", "litellm==1.82.8")
| project TimeGenerated, DeviceName, AccountName, FileName,
          ProcessCommandLine, InitiatingProcessFileName,
          InitiatingProcessCommandLine, FolderPath
| order by TimeGenerated desc

// ============================================================
// RULE 2: litellm_init.pth Hook File Created in site-packages
// Table: DeviceFileEvents | T1546.018 Persistence
// ============================================================
DeviceFileEvents
| where TimeGenerated > ago(7d)
| where ActionType == "FileCreated"
| where FileName == "litellm_init.pth"
| where FolderPath has "site-packages"
| project TimeGenerated, DeviceName, AccountName, FileName, FolderPath,
          InitiatingProcessFileName, InitiatingProcessCommandLine, SHA1, MD5
| order by TimeGenerated desc

// ============================================================
// RULE 3: TeamPCP Backdoor Script or Persistence Files Created
// Table: DeviceFileEvents | T1036.005 + T1547.016
// ============================================================
DeviceFileEvents
| where TimeGenerated > ago(7d)
| where ActionType == "FileCreated"
| where (FileName == "sysmon.py" and FolderPath has ".config/sysmon")
    or  (FileName == "sysmon.service" and FolderPath has ".config/systemd/user")
    or  FileName in ("/tmp/pglog", "/tmp/.pg_state")
    or  FolderPath has "site-packages" and FileName == "litellm_init.pth"
| project TimeGenerated, DeviceName, AccountName, FileName, FolderPath,
          InitiatingProcessFileName, InitiatingProcessCommandLine
| order by TimeGenerated desc

// ============================================================
// RULE 4: DNS Query to TeamPCP C2 Typosquat Domains
// Table: DeviceNetworkEvents | T1041 Exfiltration
// ============================================================
DeviceNetworkEvents
| where TimeGenerated > ago(7d)
| where RemoteUrl has_any ("models.litellm.cloud", "checkmarx.zone")
| project TimeGenerated, DeviceName, AccountName,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          RemoteUrl, RemoteIP, RemotePort, ActionType
| order by TimeGenerated desc

// ============================================================
// RULE 5: Network Connection to TeamPCP C2 IP Infrastructure
// Table: DeviceNetworkEvents | T1041 C2
// ============================================================
DeviceNetworkEvents
| where TimeGenerated > ago(7d)
| where RemoteIP in ("45.148.10.212", "83.142.209.11")
| project TimeGenerated, DeviceName, AccountName,
          InitiatingProcessFileName, InitiatingProcessCommandLine,
          RemoteIP, RemotePort, RemoteUrl, ActionType
```

```
| order by TimeGenerated desc

// ============================================================
// RULE 6: Python Process Making Outbound C2 Connection
// Correlated: DeviceProcessEvents + DeviceNetworkEvents
// T1041 Exfiltration / T1552 Credential Access
// ============================================================
let c2_ips = dynamic(["45.148.10.212", "83.142.209.11"]);
let c2_domains = dynamic(["models.litellm.cloud", "checkmarx.zone"]);
let python_procs = DeviceProcessEvents
| where TimeGenerated > ago(7d)
| where FileName has_any ("python", "python3")
| project DeviceId, ProcessId, ProcessCommandLine, TimeGenerated;
DeviceNetworkEvents
| where TimeGenerated > ago(7d)
| where RemoteIP in (c2_ips) or RemoteUrl has_any (c2_domains)
| join kind=inner python_procs on DeviceId, $left.InitiatingProcessId == $right.ProcessId
| project TimeGenerated, DeviceName, ProcessCommandLine,
          RemoteIP, RemoteUrl, RemotePort
| order by TimeGenerated desc

// ============================================================
// SENTINEL RULE 7: Malicious pip Install from SecurityEvent
// Table: SecurityEvent (Windows) | T1195.001
// ============================================================
SecurityEvent
| where TimeGenerated > ago(7d)
| where EventID == 4688
| where CommandLine has_any ("litellm==1.82.7", "litellm==1.82.8")
| project TimeGenerated, Computer, Account, CommandLine,
          ParentProcessName, NewProcessName
| order by TimeGenerated desc
```

XQL

Palo Alto Cortex XDR · XSIAM

Six XQL stage-based pipeline queries: process start events filtering for malicious litellm versions, file create events for the .pth hook, composite artifact detection across file paths, network queries for C2 domains and IPs, a correlated rule tying Python processes to C2 network events, and a query detecting abnormal child processes (bash, curl, wget) spawned from Python. All queries use ENUM constants (ENUM.PROCESS, ENUM.FILE, ENUM.NETWORK) as required by the XQL specification.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Palo Alto Cortex XDR / XSIAM
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Author: Mazlum BAYDAR | Date: 2026-03-26
// Note: XQL uses stage-based pipeline; ENUM constants for event types

// ============================================================
// RULE 1: Malicious LiteLLM PyPI Installation
// Event: Process Start | T1195.001
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter actor_process_image_name in ("pip", "pip3", "python", "python3")
        and (actor_process_command_line contains "litellm==1.82.7"
             or actor_process_command_line contains "litellm==1.82.8")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         actor_process_image_path
| sort desc timestamp_desc
| limit 100

// ============================================================
// RULE 2: litellm_init.pth Hook File Created
// Event: File Create | T1546.018
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.FILE and event_sub_type = ENUM.FILE_CREATE_NEW
| filter action_file_name = "litellm_init.pth"
        and action_file_path contains "site-packages"
| fields timestamp_desc, agent_hostname, actor_primary_username,
         action_file_path, actor_process_image_name,
         actor_process_command_line
| sort desc timestamp_desc
| limit 100

// ============================================================
// RULE 3: TeamPCP Backdoor or Persistence Files Created
// Event: File Create | T1036.005 + T1547.016
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.FILE and event_sub_type = ENUM.FILE_CREATE_NEW
| filter (action_file_name = "sysmon.py" and action_file_path contains ".config/sysmon")
      or (action_file_name = "sysmon.service" and action_file_path contains ".config/systemd/user")
      or action_file_path in ("/tmp/pglog", "/tmp/.pg_state")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         action_file_name, action_file_path,
         actor_process_image_name, actor_process_command_line
| sort desc timestamp_desc
| limit 100

// ============================================================
// RULE 4: DNS / Network Connection to C2 Domains
// Event: Network | T1041
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.NETWORK
| filter dst_host in ("models.litellm.cloud", "checkmarx.zone")
      or dst_ip in ("45.148.10.212", "83.142.209.11")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         dst_host, dst_ip, dst_port, protocol
| sort desc timestamp_desc
| limit 100

// ============================================================
// RULE 5: Python Process Connecting to C2 Infrastructure
// Correlated process + network | T1041 + T1552
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.NETWORK
```

```
| filter dst_ip in ("45.148.10.212", "83.142.209.11")
      or dst_host in ("models.litellm.cloud", "checkmarx.zone")
| filter actor_process_image_name in ("python", "python3", "sysmon.py")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         dst_host, dst_ip, dst_port
| sort desc timestamp_desc
| limit 100

// ============================================================
// RULE 6: Abnormal Child Process Spawned from Python (C2 beacon)
// Actor: python | Action: spawn shell/curl/wget
// T1059 + T1041
// ============================================================
dataset = xdr_data
| filter event_type = ENUM.PROCESS and event_sub_type = ENUM.PROCESS_START
| filter actor_process_image_name in ("python", "python3")
        and action_process_image_name in ("curl", "wget", "bash", "sh", "nc", "ncat")
| fields timestamp_desc, agent_hostname, actor_primary_username,
         actor_process_image_name, actor_process_command_line,
         action_process_image_name, action_process_command_line
| sort desc timestamp_desc
| limit 100
```

Splunk SPL

Splunk SIEM · Sysmon Add-On

Six SPL queries using Sysmon event codes: EventCode=1 (Process Create) for malicious pip invocations, EventCode=11 (FileCreate) for .pth hook and TeamPCP artifact files, EventCode=22 (DNS Query) for C2 domain resolution, EventCode=3 (Network Connect) for C2 IP connections, and an aggregation query correlating all C2 indicators by host. Field names follow the Sysmon Add-On schema (Image, CommandLine, TargetFilename, DestinationIp, QueryName) and include CIM-compliant rename statements for portability.

```
| Comment "CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)"
| Comment "CVSS 9.4 Critical | Platform: Splunk (Sysmon + Linux TA)"
| Comment "ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552"
| Comment "Author: Mazlum BAYDAR | Date: 2026-03-26"
| Comment "Field Mapping: CIM-compliant (Sysmon TA) — EventCode 1=Process, 3=Network, 11=FileCreate"

| Comment "============================================================"
| Comment "RULE 1: Malicious LiteLLM PyPI Package Installation"
| Comment "Sysmon EventCode 1 (Process Create) | T1195.001"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=1
(Image="*/pip" OR Image="*/pip3" OR Image="*/python" OR Image="*/python3")
(CommandLine="*litellm==1.82.7*" OR CommandLine="*litellm==1.82.8*")
| rename ComputerName AS host, User AS user, Image AS process, CommandLine AS process_command_line, ParentImage AS parent_process
| table _time, host, user, process, process_command_line, parent_process
| sort - _time

| Comment "============================================================"
| Comment "RULE 2: litellm_init.pth Hook File Created (T1546.018)"
| Comment "Sysmon EventCode 11 (FileCreate)"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=11
TargetFilename="*site-packages*litellm_init.pth"
| rename ComputerName AS host, User AS user, Image AS process, TargetFilename AS file_path
| table _time, host, user, process, file_path
| sort - _time

| Comment "============================================================"
| Comment "RULE 3: TeamPCP Backdoor / Persistence Files Created"
| Comment "Sysmon EventCode 11 | T1036.005 + T1547.016"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=11
(TargetFilename="*/.config/sysmon/sysmon.py"
 OR TargetFilename="*/.config/systemd/user/sysmon.service"
 OR TargetFilename="/tmp/pglog"
 OR TargetFilename="/tmp/.pg_state")
| rename ComputerName AS host, User AS user, Image AS process, TargetFilename AS file_path
| table _time, host, user, process, file_path
| sort - _time

| Comment "============================================================"
| Comment "RULE 4: DNS Query to TeamPCP C2 Domains"
| Comment "Sysmon EventCode 22 (DNS Query) | T1041"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=22
(QueryName="models.litellm.cloud" OR QueryName="*litellm.cloud"
 OR QueryName="checkmarx.zone" OR QueryName="*.checkmarx.zone")
| rename ComputerName AS host, User AS user, Image AS process, QueryName AS dns_query
| table _time, host, user, process, dns_query
| sort - _time

| Comment "============================================================"
| Comment "RULE 5: Network Connection to C2 IPs"
| Comment "Sysmon EventCode 3 (Network Connect) | T1041"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational EventCode=3
(DestinationIp="45.148.10.212" OR DestinationIp="83.142.209.11")
| rename ComputerName AS host, User AS user, Image AS process,
```

```
         SourceIp AS src_ip, DestinationIp AS dest_ip, DestinationPort AS dest_port
| table _time, host, user, process, src_ip, dest_ip, dest_port
| sort - _time

| Comment "============================================================"
| Comment "RULE 6: Aggregated — Hosts with Multiple C2 Indicators"
| Comment "High-confidence detection combining process + network | T1041"
| Comment "============================================================"

index=linux_logs OR index=windows
sourcetype=xmlwineventlog:microsoft-windows-sysmon/operational
((EventCode=1 AND (CommandLine="*litellm==1.82.7*" OR CommandLine="*litellm==1.82.8*"))
 OR (EventCode=3 AND (DestinationIp="45.148.10.212" OR DestinationIp="83.142.209.11"))
 OR (EventCode=22 AND (QueryName="models.litellm.cloud" OR QueryName="checkmarx.zone")))
| rename ComputerName AS host
| stats count by host, EventCode
| where count >= 1
| sort - count
```

QRadar AQL

IBM QRadar SIEM

Six AQL queries using standard SQL-like syntax: command-line event search using ILIKE for case-insensitive pattern matching, file creation detection for litellm_init.pth, TeamPCP backdoor and persistence artifact search, DNS query detection using ILIKE on message content, network connection detection using the destinationIP field, and an aggregation query grouping all C2 indicator hits by source IP. Functions include QIDNAME(), LOGSOURCENAME(), CATEGORYNAME(), and DATEFORMAT() for enriched output.

```
-- CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
-- CVSS 9.4 Critical | Platform: IBM QRadar SIEM
-- ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
-- Author: Mazlum BAYDAR | Date: 2026-03-26
-- Note: Use ILIKE for case-insensitive pattern match (SQL LIKE %)
--       Use IMATCHES for case-insensitive regex (PCRE, escape dots with \.)
--       Use MATCHES for case-sensitive regex

-- ============================================================
-- RULE 1: Malicious LiteLLM PyPI Package Installation
-- T1195.001 | Source: Process/Command Audit logs
-- ============================================================
SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid) AS log_source,
    sourceIP,
    username,
    "Message" AS command_line
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%litellm==1.82.7%'
       OR "Message" ILIKE '%litellm==1.82.8%')
ORDER BY devicetime DESC
LIMIT 500

-- ============================================================
-- RULE 2: litellm_init.pth File Creation Detected
-- T1546.018 | Source: File Integrity / Endpoint logs
-- ============================================================
SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid) AS log_source,
    sourceIP,
    username,
    "Message" AS file_event
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND "Message" ILIKE '%litellm_init.pth%'
  AND "Message" ILIKE '%site-packages%'
ORDER BY devicetime DESC
LIMIT 200

-- ============================================================
-- RULE 3: TeamPCP Backdoor or Persistence Artifacts
-- T1036.005 + T1547.016 | Backdoor + systemd persistence
-- ============================================================
SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid) AS log_source,
    sourceIP,
    username,
    "Message" AS file_event
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%/.config/sysmon/sysmon.py%'
       OR "Message" ILIKE '%/.config/systemd/user/sysmon.service%'
       OR "Message" LIKE '%/tmp/pglog%'
       OR "Message" LIKE '%/tmp/.pg_state%')
ORDER BY devicetime DESC
LIMIT 200

-- ============================================================
-- RULE 4: DNS Query to TeamPCP C2 Domains
-- T1041 C2 | Source: DNS logs / Passive DNS
-- ============================================================
SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid) AS log_source,
```

```
    sourceIP,
    username,
    "Message" AS dns_query
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND ("Message" ILIKE '%models.litellm.cloud%'
       OR "Message" ILIKE '%checkmarx.zone%')
ORDER BY devicetime DESC
LIMIT 500

-- ============================================================
-- RULE 5: Network Connection to C2 IPs
-- T1041 | Match on destination IP fields
-- ============================================================
SELECT
    DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss') AS event_time,
    LOGSOURCENAME(logsourceid) AS log_source,
    sourceIP,
    destinationIP,
    destinationPort,
    username,
    "Message" AS net_event
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND destinationIP IN ('45.148.10.212', '83.142.209.11')
ORDER BY devicetime DESC
LIMIT 500

-- ============================================================
-- RULE 6: Aggregated C2 Hits by Source IP
-- High-confidence pivot — correlate all C2 indicators
-- ============================================================
SELECT
    sourceIP,
    COUNT(*) AS hit_count,
    MIN(DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss')) AS first_seen,
    MAX(DATEFORMAT(devicetime, 'yyyy-MM-dd HH:mm:ss')) AS last_seen
FROM events
WHERE devicetime > CURRENT_TIMESTAMP - 7 DAYS
  AND (destinationIP IN ('45.148.10.212', '83.142.209.11')
       OR "Message" ILIKE '%models.litellm.cloud%'
       OR "Message" ILIKE '%checkmarx.zone%'
       OR "Message" ILIKE '%litellm_init.pth%'
       OR "Message" ILIKE '%litellm==1.82.7%'
       OR "Message" ILIKE '%litellm==1.82.8%')
GROUP BY sourceIP
HAVING COUNT(*) >= 1
ORDER BY hit_count DESC
LIMIT 100
```

Carbon Black

VMware Carbon Black Cloud

Ten Lucene-based CBC queries: pip and python process queries for malicious litellm versions, filemod_name queries for the .pth hook and all TeamPCP artifact paths, netconn_ipv4 queries for C2 IPs, netconn_domain queries for C2 domains, correlated queries tying Python processes to C2 network activity, a regex-based obfuscated command detection query, and a high-volume connection detection using range syntax. All regex patterns use lowercase (CBC lowercases all indexed text) and paths use forward slashes as required.

```
# CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
# CVSS 9.4 Critical | Platform: VMware Carbon Black Cloud (CBC)
# ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
# Author: Mazlum BAYDAR | Date: 2026-03-26
#
# IMPORTANT CBC SYNTAX NOTES (from official docs):
#   - All indexed text is stored as LOWERCASE — regex must use lowercase
#   - Paths use FORWARD SLASHES: c:/windows not c:\windows
#   - Wildcard (*) works only in single terms, NOT inside quoted phrases
#   - Implicit AND between terms; use OR/NOT explicitly
#   - Regex via field:/pattern/ uses Java regex engine (all lowercase text)
#   - Range queries: field:[N TO *] (inclusive), * means infinity

# ============================================================
# RULE 1: Malicious LiteLLM PyPI Package Installation
# process_name + cmdline fields | T1195.001
# ============================================================
process_name:pip AND (cmdline:"litellm==1.82.7" OR cmdline:"litellm==1.82.8")

process_name:pip3 AND (cmdline:"litellm==1.82.7" OR cmdline:"litellm==1.82.8")

process_name:python AND cmdline:"-m" AND cmdline:"pip" AND cmdline:"install" AND (cmdline:"litellm==1.82.7" OR
cmdline:"litellm==1.82.8")

# ============================================================
# RULE 2: litellm_init.pth Hook File Created in site-packages
# filemod_name field | T1546.018
# ============================================================
filemod_name:"litellm_init.pth" AND filemod_name:*site-packages*

# ============================================================
# RULE 3: TeamPCP Backdoor Script Created
# sysmon.py file creation | T1036.005
# NOTE: CBC path uses forward slash; tilde (~) is user home
# ============================================================
filemod_name:*/.config/sysmon/sysmon.py

# ============================================================
# RULE 4: TeamPCP systemd Persistence Unit Created
# sysmon.service in user systemd path | T1547.016
# ============================================================
filemod_name:*/.config/systemd/user/sysmon.service

# ============================================================
# RULE 5: TeamPCP Temporary Payload Drop Files
# /tmp staging and state tracking | T1036
# ============================================================
(filemod_name:"/tmp/pglog" OR filemod_name:"/tmp/.pg_state")

# ============================================================
# RULE 6: Network Connection to C2 IP Infrastructure
# netconn_ipv4 field | T1041
# ============================================================
netconn_ipv4:45.148.10.212

netconn_ipv4:83.142.209.11

# ============================================================
# RULE 7: DNS Query to C2 Domains
# netconn_domain field | T1041
# Domain suffix matching uses leading dot for subdomains
# ============================================================
netconn_domain:models.litellm.cloud

netconn_domain:checkmarx.zone

# ============================================================
# RULE 8: Python Process Connecting to C2 Infrastructure
```

```
# Correlated: python process + C2 netconn | T1041 + T1552
# ============================================================
(process_name:python OR process_name:python3) AND (netconn_ipv4:45.148.10.212 OR netconn_ipv4:83.142.209.11)

(process_name:python OR process_name:python3) AND (netconn_domain:models.litellm.cloud OR netconn_domain:checkmarx.zone)

# ============================================================
# RULE 9: Obfuscated Command in Python Process (regex)
# Long base64/encoded strings in cmdline | T1027
# NOTE: regex must be all lowercase (CBC lowercases all text)
# ============================================================
process_name:/python.*/ AND cmdline:/[a-z0-9+/]{200,}/

# ============================================================
# RULE 10: Multiple C2 Connections from Same Process (volume)
# High netconn count from python | T1041
# ============================================================
(process_name:python OR process_name:python3) AND netconn_count:[10 TO *]
```

SentinelOne Deep Visibility

v2 Enhanced · STAR Rules

Ten SentinelOne DV v2 queries using dot notation (TgtFile.Path, DnsRequest.Name, Dst.IP): process creation queries for malicious pip/python invocations, file creation queries for litellm_init.pth, sysmon.py, sysmon.service, and /tmp payload files, DNS request queries for C2 typosquat domains, network connection queries for C2 IPs, a correlated query tying Python processes to C2 connections, a module load query for suspicious paths, and a composite high-confidence query combining all primary IOC classes. Uses Contains (case-insensitive) and In Contains operators appropriately.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: SentinelOne Deep Visibility (v2 Enhanced)
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Author: Mazlum BAYDAR | Date: 2026-03-26
//
// IMPORTANT S1 SYNTAX NOTES (from official docs):
//   - EventType values are exact strings (case-sensitive with double quotes)
//   - Dot notation required: TgtFile.Path (NOT TgtFilePath — that is v1 legacy)
//   - Contains = case-INSENSITIVE substring | StartsWith = case-SENSITIVE
//   - ContainsCIS = explicit case-insensitive | EndsWith = case-SENSITIVE
//   - In Contains = list-based case-insensitive contains check
//   - Regexp operator uses case-sensitive regex
//   - No aggregation in query itself — use UI time picker for time range

// ============================================================
// RULE 1: Malicious LiteLLM PyPI Package Installation
// EventType: Process Creation | T1195.001
// ============================================================
EventType = "Process Creation"
AND TgtProcName In ("pip", "pip3", "python", "python3")
AND (TgtProcCmdLine Contains "litellm==1.82.7"
     OR TgtProcCmdLine Contains "litellm==1.82.8")

// ============================================================
// RULE 2: litellm_init.pth Hook File Created (T1546.018)
// EventType: File Creation | Persistence via .pth
// ============================================================
EventType = "File Creation"
AND TgtFile.Name = "litellm_init.pth"
AND TgtFile.Path Contains "site-packages"

// ============================================================
// RULE 3: TeamPCP Backdoor Script Created
// EventType: File Creation | T1036.005
// ============================================================
EventType = "File Creation"
AND TgtFile.Name = "sysmon.py"
AND TgtFile.Path Contains ".config/sysmon"

// ============================================================
// RULE 4: TeamPCP systemd Persistence Unit Created
// EventType: File Creation | T1547.016
// ============================================================
EventType = "File Creation"
AND TgtFile.Name = "sysmon.service"
AND TgtFile.Path Contains ".config/systemd/user"

// ============================================================
// RULE 5: TeamPCP Temporary Payload Drop Files
// EventType: File Creation | T1036
// ============================================================
EventType = "File Creation"
AND TgtFile.Path In ("/tmp/pglog", "/tmp/.pg_state")

// ============================================================
// RULE 6: DNS Query to TeamPCP C2 Domains
// EventType: DNS Request | T1041
// ============================================================
EventType = "DNS Request"
AND (DnsRequest.Name = "models.litellm.cloud"
     OR DnsRequest.Name EndsWith ".litellm.cloud"
     OR DnsRequest.Name = "checkmarx.zone"
     OR DnsRequest.Name EndsWith ".checkmarx.zone")

// ============================================================
// RULE 7: Network Connection to C2 IP Infrastructure
// EventType: IP Connect | T1041
// ============================================================
```

```
EventType = "IP Connect"
AND Dst.IP In ("45.148.10.212", "83.142.209.11")

// ============================================================
// RULE 8: Python/pip Process Making Outbound C2 Connection
// Correlated: Process + Network | T1041 + T1552
// ============================================================
EventType = "IP Connect"
AND Dst.IP In ("45.148.10.212", "83.142.209.11")
AND SrcProcName In ("python", "python3", "pip", "pip3")

// ============================================================
// RULE 9: Module Loaded from Temp or site-packages by Python
// EventType: Module Load | T1546.018 variant
// ============================================================
EventType = "Module Load"
AND SrcProcName In ("python", "python3")
AND (TgtModule.Path Contains "/tmp/"
     OR TgtModule.Path Contains "litellm_init")

// ============================================================
// RULE 10: TeamPCP — All Primary IOCs Combined (High Confidence)
// Composite rule for alerting | Multiple ATT&CK techniques
// ============================================================
(
  (EventType = "Process Creation"
   AND TgtProcCmdLine In Contains ("litellm==1.82.7", "litellm==1.82.8"))
  OR
  (EventType = "File Creation"
   AND TgtFile.Name In ("litellm_init.pth", "sysmon.py", "sysmon.service"))
  OR
  (EventType = "DNS Request"
   AND DnsRequest.Name In ("models.litellm.cloud", "checkmarx.zone"))
  OR
  (EventType = "IP Connect"
   AND Dst.IP In ("45.148.10.212", "83.142.209.11"))
)
```

Kaspersky EDR Expert

KEDR · KATA

Twelve KEDR queries using UPPERCASE operator convention: process queries with CONTAINS for malicious litellm versions, file queries for the .pth hook and persistence artifacts, network queries for C2 domains and IPs, a correlated rule linking Python processes to C2 connections, a child process spawn detection, an obfuscated payload regex using MATCHES with PCRE syntax, a SHA256 hash indicator query, and a comprehensive composite alert rule covering all primary IOC classes using nested boolean logic. Avoids TAA reserved fields per official documentation.

```
// CVE-2026-33634 — LiteLLM PyPI Supply Chain Attack (TeamPCP)
// CVSS 9.4 Critical | Platform: Kaspersky EDR Expert (KEDR) / KATA
// ATT&CK: T1195.001, T1546.018, T1547.016, T1041, T1552
// Author: Mazlum BAYDAR | Date: 2026-03-26
//
// IMPORTANT KEDR SYNTAX NOTES (from official docs):
//   - ALL operators must be UPPERCASE: CONTAINS, STARTS_WITH, ENDS_WITH, IN, MATCHES, AND, OR, NOT
//   - Field names use dot notation: Process.Name, File.Path, Network.DestinationIP
//   - CONTAINS, STARTS_WITH, ENDS_WITH, IN are case-INSENSITIVE by default
//   - MATCHES uses full PCRE regex (case-SENSITIVE by default)
//   - String values in double quotes; numeric values without quotes
//   - Use parentheses for grouping complex boolean logic
//   - Do NOT use TAA reserved fields: IOATechnique, IOATactics, IOAImportance, IOAConfidence

// ============================================================
// RULE 1: Malicious LiteLLM PyPI Package Installation
// T1195.001 | Process: pip/python with malicious version
// ============================================================
Process.Name IN ("pip", "pip3", "python", "python3")
AND (Process.CommandLine CONTAINS "litellm==1.82.7"
     OR Process.CommandLine CONTAINS "litellm==1.82.8")

// ============================================================
// RULE 2: litellm_init.pth Hook File Created (T1546.018)
// File.Path in site-packages + filename match
// ============================================================
File.Name = "litellm_init.pth"
AND File.Path CONTAINS "site-packages"

// ============================================================
// RULE 3: TeamPCP Backdoor Script Created at Hidden Path
// T1036.005 — Masquerading as legitimate sysmon
// ============================================================
File.Name = "sysmon.py"
AND File.Path CONTAINS ".config/sysmon"

// ============================================================
// RULE 4: TeamPCP systemd Persistence Unit Created (T1547.016)
// User-level systemd service for reboot persistence
// ============================================================
File.Name = "sysmon.service"
AND File.Path CONTAINS ".config/systemd/user"

// ============================================================
// RULE 5: TeamPCP Temporary Payload Files in /tmp
// /tmp/pglog = payload drop | /tmp/.pg_state = infection state
// ============================================================
File.Path IN ("/tmp/pglog", "/tmp/.pg_state")

// ============================================================
// RULE 6: DNS / Network Connection to TeamPCP C2 Domains
// T1041 | Exfiltration over encrypted channel
// ============================================================
Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone")

// ============================================================
// RULE 7: Network Connection to TeamPCP C2 IP Infrastructure
// T1041 | Direct IP C2 communication
// ============================================================
Network.DestinationIP IN ("45.148.10.212", "83.142.209.11")

// ============================================================
// RULE 8: Python Process Communicating with C2 Infrastructure
// Correlated: python + C2 network activity | T1041 + T1552
// ============================================================
Process.Name IN ("python", "python3", "pip", "pip3")
AND (Network.DestinationIP IN ("45.148.10.212", "83.142.209.11")
     OR Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone"))
```

```
// ============================================================
// RULE 9: Suspicious Python Child Process Spawned (C2 beacon)
// T1059 — Command execution via backdoor
// ============================================================
Process.ParentName IN ("python", "python3")
AND Process.Name IN ("bash", "sh", "curl", "wget", "nc")

// ============================================================
// RULE 10: Obfuscated Payload Pattern in Python CommandLine
// T1027 — Long encoded strings (base64/hex) in cmdline
// MATCHES uses PCRE — case sensitive; long token = encoded payload
// ============================================================
Process.Name IN ("python", "python3")
AND Process.CommandLine MATCHES ".*[A-Za-z0-9+/=]{200,}.*"

// ============================================================
// RULE 11: TeamPCP SHA256 Hash Match
// Direct indicator — litellm_init.pth malicious payload
// Hash: ceNa7wMJnNHy1kRnNCcwJaFjWX3pORLfMh7xGL8TUjg (base64url)
// ============================================================
File.Name = "litellm_init.pth"
AND Process.Name IN ("python", "python3", "pip", "pip3")

// ============================================================
// RULE 12: TeamPCP — High Confidence Composite Alert
// Multiple IOC classes combined (OR logic) for SIEM alerting
// ============================================================
(
  (Process.CommandLine CONTAINS "litellm==1.82.7"
   OR Process.CommandLine CONTAINS "litellm==1.82.8")
  OR
  (File.Name IN ("litellm_init.pth", "sysmon.py", "sysmon.service")
   AND (File.Path CONTAINS "site-packages"
        OR File.Path CONTAINS ".config/sysmon"
        OR File.Path CONTAINS ".config/systemd/user"))
  OR
  Network.DestinationIP IN ("45.148.10.212", "83.142.209.11")
  OR
  Network.DestinationHost IN ("models.litellm.cloud", "checkmarx.zone")
)
```

5. References

Source	URL
Sysdig Threat Research	https://sysdig.com/blog/teampcp-pypi-supply-chain/
FutureSearch	https://futuresearch.ai/blog/litellm-pypi-supply-chain-attack/
Snyk Security	https://snyk.io/articles/poisoned-security-scanner-backdooring-litellm/
Datadog Security Labs	https://securitylabs.datadoghq.com/articles/litellm-compromised-pypi-teampcp-supply-chain-campaign/
Sonatype	https://www.sonatype.com/blog/litellm-pypi-supply-chain
ARMO Security	https://www.armosec.io/blog/teampcp-kubernetes-attack/
Kaspersky	https://www.kaspersky.com/blog/critical-supply-chain-attack-trivy-litellm-checkmarx-teampcp/55510/
ReversingLabs YARA Rules	https://github.com/reversinglabs/reversinglabs-yara-rules
NVD — CVE-2026-33634	https://nvd.nist.gov/vuln/detail/CVE-2026-33634